CYBERCUP 6.0 HACKATHON BRIEFING • PROBLEM STATEMENT CC6-AI03

AEGIS-AI

Enterprise AI Security Gateway & SOC Telemetry Dashboard

Core Mission An inline, zero-knowledge reverse proxy securing enterprise LLM adoption against data leakage, adversarial prompt injections, and cross-role RAG privilege escalations.	**Target Track** CyberCup 6.0 • CC6-AI03 AI Data Leakage & Injection Prevention	**Key Features** • 9-Step Zero-Trust Pipeline • SHA-256 Hash Chained Audit • Multi-Modal OCR Visual Redaction

Architecture: Next.js 15 App Router • Python FastAPI & OpenCV Engine • Provider Adapters (OpenAI / Claude / Mock) • Production Ready

The Enterprise AI Dilemma: Innovation vs Exposure

As enterprises adopt LLMs (OpenAI, Anthropic, Gemini), employees inadvertently compromise compliance and IP.

1. Accidental PII / Secret Leaks	2. Adversarial Prompt Injection
Employees paste sensitive customer data (Indian PAN, phone numbers, corporate emails, AWS keys, sk- tokens) directly into LLM prompt boxes. Model memory and external logging ingest this unencrypted confidential data.	Direct and indirect jailbreak commands (e.g., 'ignore previous instructions', 'system override', Base64 payloads, DAN mode) bypass foundational alignment to dump proprietary system prompts and instructions.
3. Cross-Tenant / Cross-Role RAG Leakage	**4. Egress Canary & Credential Exfiltration**
Enterprise Vector Stores retrieve all relevant text chunks based solely on semantic similarity without evaluating user RBAC credentials. Interns and external contractors receive confidential C-Suite compensation and M&A; data.	Upstream models echo internal tripwire tokens (canary keys) or database connection strings back to unauthorized clients, enabling egress exfiltration and supply-chain reconnaissance.

System Architecture: Inline Reverse-Proxy Boundary

A zero-trust middleware interceptor positioned between enterprise client interfaces and upstream foundation models.

Client Workspaces	AEGIS-AI Gateway Boundary (Port 3000 / 8000)	Upstream AI Providers
• Enterprise Web UI • CLI & API Endpoints • Signed HMAC Role Tokens • Multi-Modal Documents	**1. Inbound Modality Scanner:** Text & image payload validation **2. Local OCR Engine:** RapidOCR + cv2 visual bounding boxes **3. Sensitive Sanitizer:** PAN, phone, email, API key surrogates **4. Injection Guard:** Regex & heuristic analyzer → 403 Block **5. RBAC-Filtered RAG:** Pre-retrieval role clearance barrier **6. Provider Adapter:** Server-only key vault (OpenAI, Claude) **7. Egress Guard:** Canary neutralization & secret scrub **8. Audit Ledger:** Immutable SHA-256 hash-chained log	• OpenAI (GPT-4o, Mini) • Anthropic (Claude 3.5) • Local Test Simulator • Enterprise Vector Store • Zero Raw PII Transmitted

Key Security Invariant: No raw prompts, raw keys, or unmasked identifiers ever reach external provider clusters or persistent database storage.

The 9-Step Zero-Trust Gateway Pipeline

Every inbound transaction is scrutinized through a sequential multi-stage inspection lifecycle.

Stage	Operation	Security Enforcement & Technique	Output Action
1. Router	Inbound Modality & Rate Limit	Validates size (<50KB), checks 60 req/min rate limit, verifies HMAC role token.	PASS / 429
2. OCR Redact	Computer Vision Redaction	RapidOCR extracts coordinates; OpenCV draws solid blackout boxes over IDs.	REDACT
3. PII Sanitizer	Regex & Entity Tokenizer	Detects Indian PAN, phone, email, and API keys. Maps to reversible [PAN_1] tokens.	TOKENIZE
4. Injection	Adversarial Heuristics	Scans for jailbreaks, system prompt overrides, developer mode tricks.	BLOCK (403)
5. RBAC RAG	Pre-Retrieval Clearance	Filters knowledge base chunks against role level BEFORE prompt augmentation.	QUARANTINE
6. Provider Call	Upstream AI Dispatch	Transmits only sanitized context to external model. Gateway timer pauses.	INFERENCE
7. Egress Scan	Outbound Canary Guard	Scans reply for AEGIS-CANARY-SEC-99823 or leaked credentials; neutralizes tokens.	SCRUB
8. Telemetry	Overhead & Action Tagging	Computes clean gateway overhead ms (excluding provider response delay).	TAG <15ms
9. Ledger	Hash Chained Audit	Writes zero-knowledge SHA-256 record linked to previous hash (tamper evident).	COMMIT

Stage 5 Deep Dive: Access-Controlled RAG via RBAC

Standard RAG pipelines blindly retrieve data based on cosine similarity. AEGIS enforces clearance gates before context generation.

Role Clearance Hierarchy

• **Level 1: Intern / Contractor**
Clearance: PUBLIC only.
Strictly barred from engineering internals, financial ledgers, and executive records.

• **Level 2: Standard Developer / Employee**
Clearance: PUBLIC + INTERNAL.
Accesses architecture diagrams and engineering specs. Barred from compensation & M&A; records.

• **Level 3 / 4: Executive / Finance Specialist**
Clearance: FULL CLEARANCE.
Authorized to query Q4 payroll, EBITDA metrics, and Project Titan acquisition files.

Enterprise Knowledge Base Categorization

[DOC-PUB-01] General Engineering Guidelines & Coding Standards
Classification: PUBLIC • Min Role: Intern • Authorized for all tiers.

[DOC-DEV-02] Microservices Architecture & Gateway Specs
Classification: INTERNAL • Min Role: Developer • Quarantined for Interns.

[DOC-EXEC-03] Q4 Executive Compensation & M&A; Strategy
Classification: RESTRICTED • Min Role: Executive • Quarantined for Developers and Interns.

Verified Test: Intern query for 'Q4 compensation' returned 0 unauthorized chunks and logged an RBAC_VIOLATION event.

Stage 2 Deep Dive: Computer Vision & OCR Visual Redaction

Employees frequently upload image attachments (ID cards, payroll slips, invoices). AEGIS-AI scrubs them before upload.

1. Modality Inspection	2. RapidOCR Coordinates	3. OpenCV Blackout Bounding Boxes
Accepts multi-modal inputs (PNG, JPG, WebP) up to 10MB. Computes SHA-256 payload digest. Routes payload directly to local FastAPI microservice without third-party network transit.	RapidOCR (ONNX model engine) performs local, high-speed optical character recognition in under 120ms. Detects text polygons, character bounding boxes, and recognition confidence scores.	Executes **cv2.rectangle(img, pt1, pt2, (0,0,0), -1)** solid black-out fill over detected sensitive regions (PAN numbers, dates of birth, phone numbers, account balances). Generates clean sanitized image.

Guaranteed Privacy Guarantee: The upstream multimodal LLM receives ONLY the redacted image with blacked-out bounding boxes. The original unredacted image never leaves the gateway boundary.

Stage 9 Deep Dive: Zero-Knowledge Hash-Chained Audit Ledger

A tamper-evident, cryptographically linked SOC audit store guaranteeing immutable compliance logging.

Cryptographic Chaining Mechanism	Zero-Knowledge Privacy Rules
• **Genesis Block:** 64 hex zeros. • **Linkage:** Each audit record computes its SHA-256 digest over the concatenation of the previous entry's hash and the canonical JSON metadata: hash = SHA-256(previous_hash + canonical_json) • **Automated Verification:** Built-in **verifyChain()** traverses the ledger. Any modification to past entries breaks downstream hashes immediately.	• **Zero Plaintext Stored:** Raw prompts, raw LLM replies, unredacted PII values, and token maps are NEVER written to disk or audit logs. • **Hidden-Length Block Descriptors:** Only metadata like **[PAN: 10 chars]** and surrogate tags **[PAN_1]** are persisted. • **Export Compliance:** Downloadable **aegis-audit-ledger.json** allows SecOps teams to verify ledger integrity independently.

Minimalist User Experience & SOC Inspector Cockpit

Designed with consumer AI familiarity (ChatGPT/Gemini feel) paired with deep enterprise SecOps controls.

End-User AI Workspace	SOC Telemetry & Inspection Drawer
• **Distraction-Free Conversation:** Centered reading column (max-w-3xl), neutral dark canvas (#212121), clean typography. • **Subtle Gateway Feedback:** Amber tags for masked entities, clean emerald for safe passes, bold crimson cards for 403 blocks. • **Dynamic Role Switcher:** Role token signed via server HMAC. • **Client Sanitization:** Raw PII is never stored in browser React state; inputs display hidden-length blocks.	• **Slide-Over Inspector Drawer:** Toggled via top-right shield button. • **'Before & After' Diff Viewer:** Compares user input (hidden-length blocks) with transmitted surrogate tokens ([PAN_1]). • **Live Hash Chain Ledger:** Real-time visualization of SHA-256 blocks with verified status badge. • **JSON Ledger Export:** One-click export for regulatory audit filing.

Rigorous Verification & Test Results

100% of pipeline stages and API endpoints are tested and verified via automated test suites.

8 / 8	8 / 8	14 ms	0 Violations
Unit Tests Passed PAN, phone, email, API key block, injection block, RBAC RAG, canary, hash chain.	**Server Endpoints Live** /, /api/models, /api/auth, /api/chat, /api/audit, /export, /privacy, /terms.	**Average Overhead** Sub-15ms inline security processing latency across all 9 gateway steps.	**Strict Design Compliance** Zero purple/violet, zero gradients, zero em dashes, 8-12px radii, no fake data.

Test Execution Command: npm test (runs Node.js test runner with tsx) • node scripts/test_endpoints.js (verifies HTTP 200 & 403 on live server).

Business Value, Regulatory Compliance & Roadmap

Accelerating enterprise AI adoption while eliminating non-compliance liabilities.

Enterprise Regulatory Compliance	Competitive Edge & Roadmap
• **DPDP Act (India) & GDPR:** Automates lawful handling of personally identifiable identifiers with zero persistent storage. • **SOC 2 Type II Readiness:** Cryptographic SHA-256 hash chaining satisfies strict tamper-evidence logging controls. • **Intellectual Property Protection:** Neutralizes prompt extraction and canary token egress before secrets leak to public models.	• **Zero Friction Deployment:** Operates as an inline HTTP proxy requiring no changes to client code or LLM fine-tuning. • **Production Scaling:** Microservices architecture with FastAPI OCR container and stateless Next.js gateway. • **Future Roadmap:** - Integration with enterprise SIEMs (Splunk, Datadog). - On-prem air-gapped deployment with local vLLM / Ollama clusters. - Custom fine-tuned SLM for zero-day jailbreak detection.